
SESIÓN 5 DE 6 · 5 HORAS · BLOQUE 9: 2H15 · DESCANSO 30 MIN · BLOQUE 10: 2H15

CERTIFICADOS Y CANAL SEGURO

¿DE QUIÉN ES ESA LLAVE PÚBLICA, Y QUIÉN LO CERTIFICA?

SIO0010 · Técnicas Criptográficas · Especialización en Seguridad de la Información de las Organizaciones · Facultad de Ingeniería · Institución Universitaria de Envigado

SECCIÓN

01

LA PREGUNTA QUE QUEDÓ ABIERTA

El jueves firmamos y verificamos. Faltaba saber de quién era la llave

AGENDA DE LA SESIÓN

Hoy se cierra el medio problema que quedó pendiente: cómo se sabe que una llave pública pertenece a quien dice pertenecer. Y con eso se puede leer, por fin, la evidencia A del caso.

BLOQUE	MINUTOS	CONTENIDO	MODALIDAD
Bloque 9	0 – 20	Realimentación de la entrega 4	Taller
	20 – 80	El certificado: qué es, qué contiene, sus formatos y los modelos de confianza	Magistral
	80 – 135	Ciclo de vida: emisión, revocación, vencimiento, ACME y autoridades que fallaron	Magistral
Descanso	30		
Bloque 10	0 – 70	El canal seguro, TLS 1.3 mensaje por mensaje y el hallazgo H5	Magistral y taller
	70 – 120	Laboratorio 5, con el ejercicio en Python	Laboratorio
	120 – 135	Entrega 5, trabajo independiente y cierre	Taller

DONDE NOS QUEDAMOS EL JUEVES

La sesión anterior terminó con una frase incómoda: una firma puede verificar perfectamente y no probar nada. Conviene entender bien por qué antes de seguir.

// LO QUE YA TENEMOS

Una firma digital demuestra que quien firmó poseía una llave privada determinada, y que el contenido no cambió después.

Eso es mucho, y es lo único que da no repudio.

// LO QUE FALTA

Nada de eso dice **de quién es** esa llave privada.

Si alguien me entrega una llave pública diciendo que es del banco, y verifico con ella, verifico correctamente firmas del atacante.

Es el mismo ataque del intermediario de la sesión pasada, ahora en el terreno de la identidad.

// LA SOLUCIÓN NO ES TÉCNICA, ES DE CONFIANZA

Hace falta que **alguien en quien ya confío** afirme, de forma verificable, que esa llave pública es de esa persona. Ese alguien es una entidad de certificación, y su afirmación es un certificado.

REALIMENTACIÓN DE LA ENTREGA 4

Veinte minutos sobre el cierre del rediseño de la firma y el plan de choque de certificados. Dos observaciones que aplican a casi todos los informes.

// EL ENROLAMIENTO ES EL PUNTO DÉBIL

Casi todos describieron bien cómo se genera la llave en el dispositivo y cómo se firma.

Muy pocos describieron **cómo se verifica la identidad del asociado el día que enrola el teléfono.**

Toda la cadena de no repudio descansa en ese momento: si ahí entra un impostor, el resto del esquema le da una prueba en contra de otra persona.

// EL PLAN DE CHOQUE SE QUEDÓ CORTO

Comprar un certificado público para el portal resuelve la advertencia, pero no resuelve el hallazgo.

La pregunta que casi nadie hizo: **¿dónde más está instalada esa raíz interna y para qué se usa?**

Hoy vamos a ver por qué esa es la pregunta cara.

SECCIÓN

02

EL CERTIFICADO

Un documento firmado cuyo único trabajo es atar una llave pública a una identidad

QUÉ ES UN CERTIFICADO

Un certificado no es un secreto, no cifra nada y no protege nada por sí mismo. Es una afirmación firmada, y su valor es exactamente el de quien la firma.

LA AFIRMACIÓN QUE CONTIENE UN CERTIFICADO

Un certificado dice, en esencia, una sola cosa:

"Yo, la entidad E, afirmo que la llave pública K pertenece al sujeto S,
para los usos U, entre las fechas F1 y F2."
– firmado digitalmente por E

Todo lo demás son detalles de formato. Y la verificación de ese documento es exactamente la que aprendimos el jueves: verificar una firma digital.

// EL DESPLAZAMIENTO DEL PROBLEMA

Fíjense en lo que acaba de pasar: para confiar en la llave de S, ahora tengo que confiar en la llave de E. **El problema no se resolvió, se desplazó**, y se desplazó de 142.000 llaves a unas pocas decenas de entidades. Eso sí es manejable, y en eso consiste toda la infraestructura.

QUÉ CONTIENE REALMENTE

CAMPO	QUÉ DICE	POR QUÉ IMPORTA
Sujeto y nombres alternativos	A quién identifica y qué dominios ampara	El navegador compara el sitio contra los nombres alternativos, no contra el sujeto
Llave pública y su algoritmo	La llave que se está certificando	Es el objeto de toda la afirmación
Emisor	Quién firmó este certificado	Determina a quién hay que subir en la cadena
Vigencia	Desde cuándo y hasta cuándo vale	Un certificado vencido no es un aviso: deja de ser válido
Usos y usos extendidos	Para qué sirve esta llave: servidor, cliente, firma de código, correo	Un certificado de servidor no debería servir para firmar software
Restricciones básicas	Si el titular es o no una autoridad, y cuántos niveles puede emitir	Sin esta comprobación, cualquier certificado podría emitir otros
Número de serie y puntos de revocación	Su identificador único y dónde consultar si sigue vigente	Es lo que permite anularlo antes de que venza

UN CERTIFICADO REAL, LEÍDO

Esta es la evidencia A del caso, en el formato en que ustedes la van a ver en el laboratorio. Cada línea dice algo.

EVIDENCIA A • CERTIFICADO DEL PORTAL

Certificate:

Serial Number: 4a:1f:... ← identificador para revocar
Signature Algorithm: sha256WithRSAEncryption ← aceptable hoy
Issuer: CN = Coopaburra Root CA 2019 ← ¿y quién confía en esa?
Validity
Not Before: Jun 14 00:00:00 2023 GMT
Not After : Jun 14 00:00:00 2026 GMT ← la cuenta regresiva
Subject: CN = portal.coopaburra.com
Subject Public Key Info: RSA Public-Key: (2048 bit) ← no es débil
X509v3 Basic Constraints: CA:FALSE

// LO QUE EL CASO ADVIERTE Y CONVIENE REPETIR

El certificado en sí no es débil. RSA 2048 con SHA-256 es aceptable. El problema no está en ninguna línea de criptografía: está en el emisor, en quién tiene esa llave y en la fecha.

LOS ARCHIVOS DE UN CERTIFICADO

En una auditoría los certificados aparecen como archivos con extensiones distintas, y confundirlos tiene consecuencias: uno de esos formatos lleva la llave privada adentro.

FORMATO	QUÉ CONTIENE	CÓMO SE RECONOCE	CUIDADO
DER	El certificado X.509 en binario	Extensión .der o .cer; ilegible en un editor	Ninguno especial: es público
PEM	El mismo contenido en Base64, entre encabezados	Empieza con BEGIN CERTIFICATE	Si dice BEGIN PRIVATE KEY, es la llave privada
PKCS #12	Certificado, cadena y llave privada, protegidos con contraseña	Extensión .p12 o .pfx	Es la llave: se custodia como tal
CSR	La solicitud que se envía a la entidad	Empieza con BEGIN CERTIFICATE REQUEST	Pública: no contiene la privada

// EL HALLAZGO TÍPICO

Un archivo .pfx en una carpeta compartida, en un correo o en un repositorio, con una contraseña débil. **Es la llave privada del servidor con un candado de juguete**, y esa contraseña se ataca sin conexión, como en la sesión 3.

LA SOLICITUD DE CERTIFICADO: QUÉ SE ENVÍA Y QUÉ NUNCA

Para obtener un certificado no se le entrega nada secreto a la entidad. El procedimiento correcto está diseñado para que la llave privada nunca salga de donde se generó.

- 01** **Se genera la pareja de llaves en el servidor, o mejor, en su módulo de hardware**
La llave privada nace ahí y ahí se queda.
- 02** **Se arma la solicitud: llave pública, nombres que debe amparar y datos de la organización**
Es un documento público, que cualquiera podría leer sin consecuencia.
- 03** **La solicitud se firma con la llave privada y se envía a la entidad**
Esa firma prueba que quien pide el certificado tiene la llave privada correspondiente.
- 04** **La entidad verifica el dominio o la organización y devuelve el certificado firmado**
Lo que vuelve es público: se instala junto a la llave privada, que nunca se movió.

// SEÑAL DE ALARMA

Si un proveedor ofrece «generarle la llave y el certificado» y enviárselos por correo, **esa llave ya no está bajo su control exclusivo**: alguien más la tuvo. Para un servidor es un riesgo; para la firma digital de una persona, destruye el no repudio.

LA CADENA DE CONFIANZA

Ningún certificado se valida solo. Se valida subiendo, firma por firma, hasta llegar a algo en lo que el verificador ya confiaba de antemano.

TRES NIVELES, UNA SOLA IDEA

RAÍZ	autofirmada · está preinstalada en el sistema operativo y en el navegador. Es el punto de partida de la confianza.
firma	
INTERMEDIA	emitida por la raíz. Es la que trabaja todos los días.
firma	
FINAL	el certificado del portal, del correo o de la persona.

Validar = verificar cada firma hacia arriba hasta llegar a una raíz
que YA estaba en mi almacén de confianza.

// POR QUÉ EXISTE LA INTERMEDIA Y NO SE EMITE DESDE LA RAÍZ

Porque la llave de la raíz se guarda desconectada, en un módulo de hardware, y solo se saca en ceremonias registradas. **Si se compromete una intermedia se revoca y se emite otra; si se compromete la raíz hay que reemplazarla en todos los equipos del mundo.** Esa asimetría es todo el diseño.

LO QUE UN NAVEGADOR COMPRUEBA EN CADA VISITA

Ocho comprobaciones, en milisegundos, cada vez que alguien abre el portal. Conocerlas permite diagnosticar con precisión en vez de decir que el sitio da error.

COMPROBACIÓN	SI FALLA, SIGNIFICA
La cadena llega a una raíz de confianza	Emisor desconocido. Es exactamente lo que le pasa hoy a Coopaburrá
Cada firma de la cadena es válida	La cadena está rota o alterada
La fecha de hoy cae dentro de toda la vigencia	Vencido o todavía no válido. También falla si el reloj del equipo está mal
El nombre del sitio está en los nombres alternativos	El certificado es real pero de otro sitio
Los usos permiten autenticar un servidor	Se está reutilizando un certificado para lo que no es
Los intermedios están marcados como autoridad	Alguien intenta emitir certificados con un certificado común
No figura como revocado	Fue anulado antes de vencer, con las limitaciones que veremos
Los algoritmos siguen siendo aceptables	Por esto dejaron de funcionar los certificados firmados con SHA-1

QUIÉN DECIDE EN QUIÉN CONFÍA SU COMPUTADOR

El almacén de confianza es una lista de raíces que alguien decidió por usted. Saber quién y cómo se puede modificar es lo que convierte esta sesión en un asunto de gobierno y no de técnica.

// QUIÉN LA CONTROLA

El fabricante del sistema operativo y el del navegador, mediante programas de raíces con auditorías anuales.

Una entidad puede ser expulsada de esas listas, y ha ocurrido: varias autoridades perdieron la confianza del sector por emitir mal.

En una organización, además, el área de tecnología puede **añadir raíces propias** a todos los equipos.

// POR QUÉ ESO ÚLTIMO ES DELICADO

Añadir una raíz propia significa que quien controle su llave privada puede suplantar cualquier sitio ante esos equipos **sin ninguna advertencia**.

Es una decisión legítima y frecuente, y es exactamente lo que hizo Coopaburrá en 2019.

Lo que no hizo fue tratar esa llave como lo que es: la llave maestra de la organización.

TRES FORMAS DE DECIDIR EN QUIÉN CONFIAR

La jerarquía de autoridades no es la única forma de atar una llave a una identidad. Hay otras dos que aparecen en la práctica, y conviene reconocerlas.

MODELO	CÓMO FUNCIONA	DÓNDE SE USA	SU DEBILIDAD
Jerarquía de autoridades	Una raíz de confianza firma intermedias, que firman los certificados finales	Navegadores, firma digital, canal seguro	Una raíz comprometida afecta todo lo que está debajo
Red de confianza	Cada usuario firma las llaves de quienes conoce y confía en las firmas de otros	Correo cifrado con PGP	Difícil de escalar y de revocar
Confianza en el primer uso	Se acepta la llave la primera vez y se alerta si cambia después	Acceso remoto a servidores con SSH	La primera conexión queda sin protección

// PARA EL INVENTARIO DEL CASO

Las tres pueden aparecer en una organización como Coopaburrá: la jerarquía en el portal, la confianza en el primer uso en el acceso de los administradores a los servidores, y quizá correo cifrado en alguna área. **Cada una tiene llaves que inventariar.**

HUELLA DIGITAL Y CERTIFICADOS COMODÍN

// LA HUELLA DIGITAL

Es el resumen del certificado completo. Sirve para comparar dos certificados sin leerlos campo por campo.

Es lo que se compara cuando alguien dicta por teléfono si el certificado del servidor es el correcto.

Cambia con cada renovación, aunque la llave sea la misma. **La huella de la llave pública, en cambio, sobrevive a la renovación**, y por eso es la que se usa para fijar.

// EL CERTIFICADO COMODÍN

Un solo certificado que ampara todos los nombres de un nivel: portal, correo, pagos.

Cómodo y barato, y por eso muy usado.

El problema: **una sola llave privada copiada en muchos servidores**. Quien comprometa el más descuidado puede suplantar a todos los demás.

En una entidad vigilada, conviene un certificado por servicio y con responsable nombrado.

LA AUTORIDAD INTERNA QUE SÍ TIENE SENTIDO

Conviene no salir de aquí con la conclusión equivocada. El error de Coopaburrá no fue tener una autoridad propia: fue tenerla sin el oficio que la acompaña. Una autoridad interna bien hecha es una decisión correcta y frecuente.

ASPECTO	AUTORIDAD INTERNA BIEN HECHA	LA DE COOPABURRÁ
Para qué se usa	Autenticar máquinas y servicios internos entre sí	Se usó para el portal público, que es justo para lo que no sirve
Dónde vive la llave raíz	En un módulo de hardware, desconectada, con doble control	En un computador de escritorio sin contraseña de arranque
Quién responde	Custodios nombrados, con acta y suplentes	Un contratista que se fue en 2022
Qué registro existe	Inventario de lo emitido, ceremonias documentadas, auditoría anual	Ninguno. No se sabe qué emitió
Cómo termina	Con plan de renovación y de retiro, definido desde el primer día	Con una fecha de vencimiento que nadie vio venir

CERTIFICADOS DE PERSONA: LOS QUE SIRVEN PARA FIRMAR

Hasta aquí hablamos de certificados de servidor. Los que necesita el hallazgo H7 son de otro tipo: identifican a una persona y habilitan la firma digital con las presunciones de la ley.

CRITERIO	CERTIFICADO DE SERVIDOR	CERTIFICADO DE PERSONA
A quién identifica	Un nombre de dominio	Una persona, con su cédula, o su vínculo con una organización
Uso de la llave	Autenticar un servidor en el canal seguro	Firma con compromiso sobre el contenido: da no repudio
Dónde vive la llave privada	En el servidor o en su módulo de hardware	Token, tarjeta o servicio de firma, bajo control del titular
Quién lo emite en Colombia	Cualquier entidad reconocida por los navegadores	Una entidad de certificación acreditada ante el ONAC
Variantes habituales	Uno o varios dominios	Persona natural, representante legal, función pública

// PARA LA ENTREGA 5

La firma de los pagarés exige un certificado de persona para cada asociado que firma una hipoteca. **No hace falta para los 142.000:** solo para quienes firman documentos que deben valer veinte años.

SECCIÓN

03

CICLO DE VIDA

Emisión, revocación y vencimiento: donde se rompen los sistemas reales

QUÉ VERIFICA LA ENTIDAD ANTES DE EMITIR

NIVEL	QUÉ COMPRUEBA	CUÁNDO USARLO
Validación de dominio	Solo que el solicitante controla el dominio. Automático, en minutos, a menudo gratuito	Sitios públicos. Es lo que el portal necesita, y bastaría para quitar la advertencia
Validación de organización	Además, la existencia legal de la entidad y su dirección	Cuando se quiere dejar constancia documental de quién responde
Validación extendida	Verificación reforzada de la persona jurídica	Su valor hoy es documental: los navegadores dejaron de mostrarla de forma distinta

// EL MALENTENDIDO COMERCIAL MÁS CARO DE ESTE TEMA

Un certificado más costoso **no cifra mejor**: la criptografía es idéntica en los tres niveles. Lo único que cambia es cuánto verificó la entidad antes de firmar. Quien venda lo contrario está vendiendo otra cosa.

CÓMO SE ANULA UN CERTIFICADO ANTES DE TIEMPO

Si una llave privada se compromete, el certificado sigue siendo criptográficamente válido hasta su vencimiento. Hay que poder decirle al mundo que ya no vale, y ese aviso funciona peor de lo que la mayoría supone.

MECANISMO	CÓMO FUNCIONA	SU PROBLEMA
Listas de revocación	La entidad publica periódicamente la lista de seriales anulados	Crecen mucho y se descargan tarde: la ventana de desfase es de horas o días
Consulta en línea	El verificador pregunta a la entidad por ese serial concreto	Añade demora, revela qué sitios visita el usuario, y ante un fallo de red se continúa igual
Grapado de la respuesta	El propio servidor adjunta una prueba reciente y firmada de que no está revocado	Hay que configurarlo. Resuelve la demora y la privacidad, y es la práctica recomendada
Listas propias del navegador	El fabricante distribuye un resumen comprimido de las revocaciones que importan	No cubre todo, pero es lo que de verdad protege hoy al usuario final

// LA CONSECUENCIA PRÁCTICA PARA EL INFORME

No se puede confiar en que revocar surta efecto inmediato. Por eso la industria dejó de apostarle a la revocación y le apostó a otra cosa: acortar la vida del certificado, que es la diapositiva siguiente.

LA VIDA DE UN CERTIFICADO SE ESTÁ ACORTANDO

Es el cambio operativo más importante de este tema en la década, y el que obliga a rediseñar la forma en que una organización administra sus certificados.

398

DÍAS
HASTA 2026

200

DÍAS
DESDE MAR. 2026

100

DÍAS
DESDE MAR. 2027

47

DÍAS
DESDE MAR. 2029

// POR QUÉ SE ACORTA

Porque la revocación no funciona bien: un certificado que vive 47 días limita el daño de una llave comprometida mucho mejor que cualquier lista.

Y porque obliga a automatizar, que es donde está el verdadero beneficio de seguridad.

// QUÉ SIGNIFICA PARA COOPABURRÁ

Renovar a mano **deja de ser viable**: con 47 días, un certificado olvidado tumba el portal ocho veces al año.

La respuesta no es comprar certificados: es automatizar la emisión y la instalación, y llevar un inventario con responsable y fecha.

ACME: LA RENOVACIÓN QUE NADIE TIENE QUE RECORDAR

La respuesta del sector a las vigencias cortas es un protocolo estándar para pedir, validar, instalar y renovar certificados sin intervención humana.

ACME • RFC 8555

1. El servidor genera su llave y pide un certificado para portal.coopaburra.com
2. La entidad le plantea un desafío: publicar un valor en el sitio o en el DNS
3. El servidor lo publica; la entidad comprueba que quien pide controla el dominio
4. La entidad emite el certificado; el servidor lo instala y recarga el servicio
5. Treinta días antes de vencer, el proceso se repite solo

// QUÉ CAMBIA PARA COOPABURRÁ

Con ACME, una vigencia de 47 días no es una carga: es invisible. **Lo que no se puede automatizar es la decisión de quién es dueño de cada certificado**, y eso vuelve al inventario. Varias entidades públicas ofrecen ACME, algunas de forma gratuita.

LOS REGISTROS PÚBLICOS DE CERTIFICADOS

Desde hace años, toda emisión de una entidad pública queda anotada en registros públicos de solo añadir, contruidos como el árbol de Merkle de la sesión 3. Es una defensa que casi nadie usa y que no cuesta nada.

// PARA QUÉ SIRVE

Si alguien emitiera un certificado para el dominio de la cooperativa sin autorización, quedaría registrado y sería detectable.

Una organización puede suscribirse a alertas sobre sus propios dominios y enterarse el mismo día.

También sirve para auditar: qué certificados existen a nombre de la entidad, emitidos por quién y cuándo.

// EL PUNTO CIEGO QUE REVELA EL CASO

Los certificados de una autoridad interna **no aparecen en ningún registro público.**

Nadie fuera de la cooperativa puede saber qué emitió esa autoridad, ni cuántos certificados existen, ni a nombre de qué.

Y dentro de la cooperativa tampoco, porque no hay inventario. Ese es el hallazgo H8 mordiendo otra vez.

CAA: DECIR QUIÉN PUEDE EMITIR PARA SU DOMINIO

Un registro en el DNS del dominio que indica qué entidades están autorizadas a emitir certificados para él. Desde 2017 todas las entidades públicas están obligadas a consultarlo antes de emitir.

REGISTRO CAA EN EL DNS • RFC 8659

```
coopaburra.com.  CAA 0 issue  "entidad-autorizada.example"  
coopaburra.com.  CAA 0 iodef  "mailto:seguridad@coopaburra.com"
```

Cualquier otra entidad debe negarse a emitir para coopaburra.com,
y si alguien lo intenta, se avisa al correo indicado.

// CUESTA CERO Y CASI NADIE LO TIENE

Es una línea en el DNS. Junto con los registros públicos de la diapositiva anterior, **convierte la emisión fraudulenta de un certificado para la cooperativa en algo difícil y, si ocurre, detectable.**

CUANDO FALLA UNA AUTORIDAD: DIGINOTAR Y SYMANTEC

El sistema de confianza depende de unas pocas decenas de entidades. Dos casos muestran qué pasa cuando una falla, y por qué los navegadores son implacables.

CASO	QUÉ PASÓ	CONSECUENCIA
DigiNotar, 2011	Un intruso emitió más de 500 certificados fraudulentos, incluido uno para los servicios de Google, usado para espiar usuarios en Irán	Retirada de todos los navegadores en días. La empresa quebró en semanas
Symantec, 2015 a 2017	Emisiones indebidas repetidas y controles insuficientes sobre socios que emitían en su nombre	Los navegadores retiraron gradualmente la confianza en todos sus certificados. El negocio se vendió

// LA LECCIÓN PARA UNA AUTORIDAD INTERNA

Si esto le pasa a entidades auditadas, con personal dedicado y controles certificados, ¿qué confianza merece una autoridad interna montada en un escritorio por un contratista? Es la pregunta que la sesión le hace al hallazgo H5.

CERTIFICADOS PARA MÁQUINAS: EL OTRO LADO DEL CANAL

Hasta aquí el certificado lo presenta el servidor y el cliente lo valida. Pero la validación puede ir en los dos sentidos, y para 32 cajeros esa es la solución del hallazgo H6.

// AUTENTICACIÓN MUTUA

El cliente también presenta un certificado y el servidor lo valida con las mismas ocho comprobaciones.

Cada equipo tiene su propia pareja de llaves, su propio certificado y su propia fecha de vencimiento.

No hay llave compartida que se pueda extraer de un equipo para suplantar a los demás.

// LO QUE RESUELVE EN EL CASO

Hoy los 32 cajeros usan llaves cargadas a mano en 2019 y nunca rotadas: si una se filtra, se filtran todas.

Con certificado por cajero, **comprometer uno no compromete ninguno más**, y revocarlo es una operación de minutos.

El costo aparece en otro sitio: hay que administrar 32 ciclos de vida en vez de uno. Eso ya no es criptografía, es gestión.

LO QUE CUESTA UN CERTIFICADO VENCIDO

La causa de caída más frecuente relacionada con certificados no es un ataque. Es una fecha que nadie estaba vigilando, y el patrón se repite en todo el mundo.

// POR QUÉ PASA SIEMPRE

Quien instaló el certificado ya no trabaja allí, o lo instaló como parte de otro proyecto.

El recordatorio quedó en el calendario de una persona, no en un proceso.

El servicio afectado suele ser interno y sin monitoreo: una cola, un servicio de pagos, un canal con un tercero.

Operadores de telefonía, plataformas de pago y servicios de gobierno han tenido caídas de alcance nacional exactamente por esto.

// LA MEDIDA MÁS RENTABLE DEL MÓDULO

Un inventario de certificados con cuatro columnas: **qué ampara, quién responde, cuándo vence y cómo se renueva.**

Con alertas a 60, 30 y 7 días, dirigidas a un rol y no a una persona.

No cuesta dinero, no requiere producto y evita la mayoría de los incidentes de este tipo.

Y es, otra vez, una porción del inventario criptográfico del hallazgo H8.

SECCIÓN

04

EL CANAL SEGURO

Bloque 10 · Cómo se usa todo lo anterior cada vez que alguien abre el portal

QUÉ PASA EN UN APRETÓN DE MANOS

Aquí se juntan las cinco sesiones anteriores. Vale la pena seguirlo paso a paso porque cada paso corresponde a algo que ya estudiamos.

- 01 El cliente saluda y propone versiones y suites, con su parte efímera del acuerdo de llave**
Acuerdo de llave sobre canal público: la sesión 4. La parte efímera es lo que da confidencialidad persistente.
- 02 El servidor responde con su parte efímera y, desde ese punto, todo va cifrado**
Ambos derivan las mismas llaves de sesión con una función de derivación: la sesión 3.
- 03 El servidor envía su certificado y firma la conversación completa**
Esa firma prueba que posee la llave privada del certificado. Sin ella, cualquiera podría reenviar un certificado ajeno.
- 04 El cliente valida cadena, fechas, nombre, usos y estado, y solo entonces continúa**
Las ocho comprobaciones de hace un rato. Aquí es donde Coopaburrá falla y aparece la advertencia.
- 05 Todo el tráfico se cifra con un modo autenticado**
AES-GCM o similar: la sesión 2. Confidencialidad e integridad en la misma operación.

EL APRETÓN DE MANOS DE TLS 1.3, MENSAJE POR MENSAJE

La misma secuencia de la diapositiva anterior, con los nombres que aparecen en una captura de tráfico. Es lo que un especialista debe poder leer en una herramienta de análisis.

TLS 1.3 • RFC 8446

Cliente → Servidor	ClientHello	versiones, suites y parte efímera del acuerdo
Servidor → Cliente	ServerHello	suite elegida y su parte efímera
	---	desde aquí todo va cifrado, con llaves derivadas por HKDF ---
	EncryptedExtensions	
	Certificate	la cadena del servidor
	CertificateVerify	firma sobre todo lo anterior: prueba la llave privada
	Finished	resumen autenticado de la conversación
Cliente → Servidor	Finished	

Un solo viaje de ida y vuelta antes de enviar datos. La versión 1.2 necesitaba dos.

// LO QUE SE VE Y LO QUE NO

En una captura solo se leen los dos primeros mensajes; el resto va cifrado, incluido el certificado. **En la versión 1.2 el certificado viajaba en claro**, y por eso muchas herramientas de monitoreo antiguas dejaron de funcionar con la 1.3.

QUÉ VERSIÓN SE USA Y CUÁL HAY QUE APAGAR

VERSIÓN	ESTADO	QUÉ HACER
TLS 1.0 y 1.1	Formalmente retiradas por el organismo de estándares en 2021. La norma de tarjetas exige apagar la 1.0 desde 2018	Apagar. Están habilitadas en el portal de Coopaburrá, según la evidencia A
TLS 1.2	Vigente y mayoritaria, pero admite suites antiguas si se configura mal	Mantener, restringiendo las suites a las que dan confidencialidad persistente
TLS 1.3	La versión moderna: menos viajes, solo acuerdos efímeros, solo modos autenticados	Habilitar y preferir. Elimina por diseño la mayoría de los errores de configuración

// LO QUE HACE FUERTE A LA VERSIÓN 1.3 NO ES UN ALGORITMO NUEVO

Es haber **quitado opciones**: eliminó los acuerdos sin confidencialidad persistente, los modos sin autenticación y las suites heredadas. Pasó de decenas de combinaciones posibles a un puñado. Menos opciones, menos formas de equivocarse.

EL CANAL SEGURO YA ES POST-CUÁNTICO, EN PARTE

La transición no es futura: ya empezó en el canal seguro. Los navegadores principales y OpenSSL 3.5 negocian hoy, por defecto, un acuerdo de llave híbrido.

ASPECTO	DETALLE
El acuerdo híbrido	X25519MLKEM768: combina la curva clásica X25519 con ML-KEM-768, el estándar post-cuántico de 2024
Por qué híbrido	Si alguno de los dos se rompe, el otro sigue protegiendo: el clásico cubre un posible fallo del nuevo, y viceversa
Qué protege	La confidencialidad del tráfico frente a quien lo grabe hoy para descifrarlo cuando exista un computador cuántico
Qué no protege todavía	La autenticación: los certificados siguen firmados con RSA o con curvas elípticas
Qué hay que revisar	Si el balanceador, el cortafuegos o el servidor del portal lo admiten, o si lo están bloqueando

// PARA COOPABURRÁ

Con TLS 1.0 y 1.1 todavía habilitados, el portal está a dos generaciones de esto. **Actualizar la configuración no solo cierra el hallazgo de hoy: pone al portal en la ruta de la transición** de la sesión 6.

LO QUE EL CANAL SEGURO NO PROTEGE

El candado del navegador se ha convertido en un símbolo de seguridad general, y no lo es. Estas cinco frases valen para el informe y para cualquier conversación con la gerencia.

CREENCIA	REALIDAD
El dato está protegido porque viaja cifrado	Protege el transporte. En el servidor llega en claro, y ahí está el hallazgo H3 esperando
Si hay candado, el sitio es legítimo	Un sitio de fraude obtiene un certificado válido gratis y en minutos. El candado dice canal cifrado, no sitio honesto
Nadie sabe qué páginas visito	El contenido va cifrado, pero el nombre del servidor y las direcciones siguen siendo observables en buena medida
Protege de todos	No protege del operador del sitio, ni de quien administre los equipos donde termina el canal
Está bien porque el navegador no se queja	Un navegador puede aceptar configuraciones antiguas sin decir nada. La ausencia de advertencia no es un diagnóstico

HSTS: QUE EL NAVEGADOR NO ACEPTE MENOS

Un canal seguro bien configurado todavía se puede saltar si el usuario llega por primera vez sin cifrado. HSTS le ordena al navegador no volver a conectarse de otra forma.

// EL ATAQUE QUE PREVIENE

El asociado escribe coopaburra.com sin «https», y la primera petición sale sin cifrar.

Un intermediario en la red del café responde él mismo y nunca lo lleva al sitio seguro: el usuario queda en una versión sin cifrar, idéntica en apariencia.

Se conoce como degradación del protocolo.

// CÓMO FUNCIONA

El sitio envía una cabecera que dice: durante un año, conéctate a mí solo con cifrado.

El navegador la recuerda y convierte cualquier intento sin cifrar en uno cifrado, antes de salir a la red.

Con la lista de precarga de los navegadores, protege incluso la primera visita.

// Y SU EFECTO SOBRE LA ADVERTENCIA

Con HSTS activo, **el navegador no deja aceptar una advertencia de certificado**: bloquea el acceso. Por eso Coopaburrá no puede activarlo hasta resolver H5, y por eso es una buena prueba de que H5 quedó resuelto.

FIJACIÓN DE CERTIFICADOS EN LA APLICACIÓN

En banca móvil no basta con validar la cadena: la aplicación suele exigir además que el certificado sea exactamente el esperado. Es una buena práctica que, mal hecha, deja la aplicación inservible.

FIJAR LA LLAVE, NO EL CERTIFICADO

La aplicación guarda la huella de la llave pública del servidor y rechaza la conexión si no coincide, aunque la cadena sea válida.

Protege de: una raíz maliciosa instalada en el teléfono del usuario,
y de una autoridad comprometida en cualquier parte del mundo.

Rompe todo si: se fija el certificado en vez de la llave pública,
o no se deja una huella de reserva para la rotación.

// POR QUÉ ESTO SE VUELVE CRÍTICO EN LOS PRÓXIMOS AÑOS

Con vigencias de 100 días en 2027, una aplicación que fije el certificado deja de funcionar tres o cuatro veces al año, y la corrección exige publicar una versión nueva en la tienda y que el usuario la instale. **Fijar la llave pública y mantener siempre una huella de reserva es la única forma sostenible.**

LA LÍNEA QUE ANULA TODA LA SESIÓN

Todo lo que hemos visto se desactiva con una sola instrucción, y es de las cosas más frecuentes que se encuentran al revisar una aplicación móvil.

DESACTIVAR LA VALIDACIÓN

```
// Aparece durante el desarrollo, para poder probar contra un servidor  
// con certificado propio. Y a veces llega a producción.
```

```
confiarEnTodosLosCertificados();  
verificadorDeNombre = ACEPTAR_CUALQUIERA;
```

Con esas dos líneas, la aplicación acepta cualquier certificado de cualquiera. Las ocho comprobaciones no se ejecutan. El candado aparece igual, el usuario no ve nada raro, y el canal ya no protege de nadie.

// CÓMO SE COMPRUEBA EN EL CASO

La evidencia D se obtuvo descompilando el paquete de la tienda pública. **El mismo procedimiento que reveló la llave de firma permite verificar si la validación del certificado está desactivada**, y esa revisión debería estar en el informe.

CÓMO SE LEE UN INFORME DE DIAGNÓSTICO DEL CANAL

Las herramientas devuelven decenas de líneas y una calificación. Saber qué mirar y qué ignorar es lo que distingue un diagnóstico de una captura de pantalla pegada en un anexo.

LO QUE APARECE

CÓMO INTERPRETARLO

Versiones antiguas habilitadas

Hallazgo real y de corrección barata. Es el primero que se corrige

Suites sin confidencialidad persistente

Hallazgo real, con impacto diferido: afecta al tráfico ya grabado

Tamaño de llave o algoritmo de firma

Verificar contra el estándar vigente antes de reportarlo. En este caso están bien

Cadena incompleta o no reconocida

Distinguir dos cosas distintas: falta un intermedio, o la raíz no es pública. Aquí es lo segundo

Advertencias de compatibilidad con equipos antiguos

No es un hallazgo de seguridad: es una decisión de negocio sobre a quién se deja de atender

Calificación global en letra

Útil para comunicar, inútil para priorizar. No la pongan como conclusión

EL OTRO CANAL SEGURO: LAS REDES PRIVADAS VIRTUALES

El respaldo que viaja a Sabaneta, los cajeros que hablan con el centro de datos y los administradores que trabajan desde casa usan otro tipo de canal seguro, con su propio inventario de llaves.

TECNOLOGÍA	DÓNDE APARECE	QUÉ HAY QUE REVISAR
IPsec con IKEv2	Enlaces entre sedes y con proveedores	Algoritmos negociados, si hay llaves compartidas débiles y quién las custodia
Red privada sobre TLS	Acceso remoto de empleados	Las mismas preguntas de hoy: versiones, suites y certificados
WireGuard	Instalaciones más recientes	Una llave por equipo, sin negociación: sencillo, pero cada llave hay que gestionarla

// UNA PREGUNTA PARA EL INFORME

El caso no documenta cómo se conectan los 32 cajeros al centro de datos. **Si lo hacen con una llave compartida por todos**, es el mismo patrón de H2 y de H6, y hay que decirlo.

SECCIÓN

05

EL HALLAZGO H5

Una autoridad certificadora, un computador sin dueño y una fecha

LA EVIDENCIA A, LEÍDA LÍNEA POR LÍNEA

LO QUE DICE LA EVIDENCIA	LO QUE SIGNIFICA	GRAVEDAD
Protocolos habilitados: TLS 1.0, 1.1 y 1.2	Dos versiones retiradas siguen aceptándose	Alta y de arreglo barato
Suites con intercambio de llave RSA, sin confidencialidad persistente	El tráfico grabado hoy se descifra el día que se comprometa la llave del servidor	Alta
Certificado RSA 2048 firmado con SHA-256	Correcto. No hay nada que reprochar aquí	Ninguna
Emisor: Coopaburra Root CA 2019	Una autoridad propia, cuya llave privada está sin custodia desde 2022	Crítica
Vigencia hasta el 14 de junio de 2026	Cuatro meses desde el diagnóstico. Con fecha cierta	Crítica y con plazo
Cadena no reconocida: advertencia en cada visita	142.000 personas entrenadas para ignorar advertencias de seguridad	Alta y de difícil reparación

QUÉ PUEDE HACER QUIEN TENGA ESA LLAVE

Esta es la diapositiva que hay que llevar al comité: no habla de criptografía, sino de lo que alguien con acceso a ese computador podría hacer hoy.

01 Emitir un certificado válido para cualquier nombre

Para el portal, para el correo interno, para la pasarela de pagos, para el sistema de los cajeros. No hay nada que se lo impida: es una autoridad.

02 Ser aceptado sin advertencia en todo equipo donde esté instalada esa raíz

Y nadie sabe en cuántos está: no hay inventario. Esa es la pregunta cara que casi nadie hizo en la entrega 4.

03 Interponerse en el tráfico interno y leerlo en claro

Con un certificado emitido por una raíz en la que el equipo confía, el ataque del intermediario no produce ninguna señal visible.

04 Y no hay forma de saber si ya ocurrió

El equipo lleva encendido y sin dueño desde 2022, sin contraseña de arranque. Ningún registro permite afirmar que la llave no fue copiada.

// LA FRASE QUE UN DIAGNÓSTICO HONESTO TIENE QUE ESCRIBIR

Nadie puede afirmar que esa llave esté comprometida, ni lo contrario. Esa es la conclusión: **una llave sin custodia durante cuatro años se asume comprometida.**

LA ADVERTENCIA QUE LOS ASOCIADOS APRENDIERON A ACEPTAR

El daño más grave del hallazgo H5 no es técnico. Durante años, 142.000 personas fueron entrenadas para hacer clic en «continuar de todos modos», y ese hábito no se borra al cambiar el certificado.

// LO QUE DICE LA INVESTIGACIÓN

Un estudio de campo de 2013, sobre millones de advertencias reales, encontró que los usuarios de un navegador principal ignoraban cerca del 70 % de las advertencias de certificado.

La tasa sube cuando la advertencia aparece siempre en el mismo sitio: el usuario aprende que no pasa nada.

// LO QUE ESO SIGNIFICA AQUÍ

El día que un atacante monte un portal falso con un certificado inválido, los asociados harán lo que se les enseñó: aceptar.

La advertencia, que es la última defensa del usuario, quedó desactivada por costumbre.

// LO QUE HAY QUE HACER ADEMÁS DEL CERTIFICADO

Comunicar a los asociados que el portal ya no mostrará advertencias, y que si alguna aparece deben detenerse. **Desentrenar es parte de la remediación**, y cuesta más que el certificado.

MONTAR UNA AUTORIDAD PROPIA NO ES AHORRAR: ES ASUMIR EL OFICIO DE UNA ENTIDAD DE CERTIFICACIÓN.

En 2019 alguien calculó lo que costaban unos certificados y decidió emitirlos en casa. Lo que no calculó fue el resto del oficio: custodia de la llave raíz en hardware dedicado, ceremonias con doble control y acta, publicación de revocaciones, auditoría periódica, renovación planificada y plan de sucesión. Ninguna de esas tareas se hizo, y todas eran parte del precio. Ese es el patrón del módulo completo: el algoritmo es gratis, el oficio alrededor es lo que cuesta.

EL PLAN DE CHOQUE, PRIORIZADO

Con cuatro horas de ventana semanal y un presupuesto acotado, el orden importa más que la lista. Este es el orden defendible, y el criterio es el que ya traen del módulo de riesgos.

ORDEN	ACCIÓN	POR QUÉ VA AHÍ
1	Certificado público de entidad acreditada para el portal, antes de junio	Tiene fecha cierta, es barato y quita la advertencia a 142.000 personas
2	Apagar y asegurar el equipo del contratista, con cadena de custodia	Es evidencia de un posible incidente: no se formatea, se preserva
3	Inventariar dónde está instalada la raíz interna y qué emitió	No se puede retirar lo que no se sabe dónde está. Es la parte lenta
4	Apagar TLS 1.0 y 1.1 y las suites sin confidencialidad persistente	Cambio de configuración, sin costo, con ventana de prueba
5	Automatizar emisión, instalación y renovación	Con vigencias de 100 días en 2027, hacerlo a mano es garantía de caída
6	Comunicar a los asociados y retirar el hábito de aceptar advertencias	Es el daño que no arregla la tecnología

EL INVENTARIO DE CERTIFICADOS: UN MODELO PARA LA ENTREGA

Así se ve un inventario de certificados bien armado. Las filas son las que el caso permite suponer; las columnas son las que el comité necesita para decidir.

CERTIFICADO	EMISOR	VENCE	RESPONSABLE	ESTADO
portal.coopaburra.com	Autoridad interna de 2019	14 de junio de 2026	Nadie asignado	Crítico: reemplazar antes de junio
Correo de la cooperativa	Por averiguar	Por averiguar	Por averiguar	Desconocido
Canal de los cajeros al centro de datos	Por averiguar	Por averiguar	Proveedor de cajeros	Desconocido
Firma de la aplicación móvil	¿La fábrica o la cooperativa?	Por averiguar	Por averiguar	Pregunta obligatoria
Redes privadas con las sedes	Por averiguar	Por averiguar	Redes	Desconocido

// LO QUE ESTA TABLA LE DICE AL COMITÉ

Una sola fila conocida y cuatro por averiguar. **Eso no es un inventario incompleto: es el hallazgo H8 en forma de tabla**, y cada «por averiguar» tiene que tener responsable y fecha en la hoja de ruta.

CÓMO SE RETIRA UNA RAÍZ INTERNA SIN TUMBAR NADA

Retirar la autoridad de 2019 es un proyecto, no un comando. Este es el orden que evita apagar servicios por accidente.

- 01 Inventariar dónde está instalada y qué emitió**
Equipos, servidores, cajeros y aplicaciones que confían en ella, y cada certificado vigente que firmó. Sin esto, cualquier paso siguiente rompe algo.
- 02 Montar el reemplazo con el oficio completo**
Una autoridad interna nueva con la raíz en módulo de hardware y ceremonia, o certificados públicos donde sirvan.
- 03 Reemitir y reemplazar, servicio por servicio**
En ventanas de mantenimiento, con prueba y plan de reversa. Primero lo que ven los asociados.
- 04 Revocar lo emitido por la raíz vieja y retirarla de los almacenes de confianza**
Solo cuando nada dependa de ella: retirarla antes tumba servicios; retirarla tarde deja la puerta abierta.
- 05 Preservar la llave vieja como evidencia**
No se destruye mientras exista la posibilidad de un incidente que investigar.

SECCIÓN

06

LABORATORIO 5

Cincuenta minutos · Inspeccionar, construir y romper una cadena, con Python

LOS CUATRO EJERCICIOS

01 Ejercicio 1 · Inspeccionar

Descarguen el certificado de un sitio real y extraigan: emisor, vigencia, nombres alternativos, usos y puntos de revocación. Comparen con la evidencia A.

02 Ejercicio 2 · Construir su propia autoridad

Creen una raíz, emitan un certificado de servidor y háganlo funcionar. Van a reproducir exactamente lo que hizo Coopaburrá en 2019, y a sentir por qué es fácil.

03 Ejercicio 3 · Romperla

Con esa misma raíz, emitan un certificado para un dominio que no es suyo. Instalen la raíz en su navegador y observen que no aparece ninguna advertencia.

04 Ejercicio 4 · Diagnosticar el canal

Revisen versiones y suites de un servidor y produzcan el listado de lo que habría que apagar, con la justificación de cada línea.

// EL EJERCICIO 3 ES EL QUE HAY QUE ENTENDER

Cuando vean su navegador aceptar sin chistar un certificado que ustedes mismos emitieron para un dominio ajeno, van a entender el hallazgo H5 mejor que con cualquier explicación. **Háganlo solo en su equipo y retiren la raíz al terminar.**

COMANDOS DE ARRANQUE

LABORATORIO 5 • PUNTO DE PARTIDA

```
# Inspeccionar el certificado de un sitio
openssl s_client -connect ejemplo.com:443 -servername ejemplo.com </dev/null \
| openssl x509 -noout -text

# Crear una raíz propia y emitir un certificado de servidor
openssl req -x509 -newkey rsa:4096 -keyout raiz.key -out raiz.crt -days 3650
openssl req -newkey rsa:2048 -keyout servidor.key -out servidor.csr -nodes
openssl x509 -req -in servidor.csr -CA raiz.crt -CAkey raiz.key \
-CACreateserial -out servidor.crt -days 365

# Verificar una cadena y revisar versiones y suites
openssl verify -CAfile raiz.crt servidor.crt
nmap --script ssl-enum-ciphers -p 443 ejemplo.com
```

LABORATORIO 5 · EL EJERCICIO EN PYTHON

El ejercicio 1 con la biblioteca estándar y la librería cryptography: descargar un certificado real y leer sus campos sin pasar por el navegador.

LABORATORIO 5 · PYTHON 3 + CRYPTOGRAPHY

```
import ssl
from cryptography import x509

pem = ssl.get_server_certificate(("www.iue.edu.co", 443))
cert = x509.load_pem_x509_certificate(pem.encode())

print("Emisor: ", cert.issuer.rfc4514_string())
print("Vigencia:", cert.not_valid_before_utc, "→", cert.not_valid_after_utc)
nombres = cert.extensions.get_extension_for_class(x509.SubjectAlternativeName)
print("Ampara: ", nombres.value.get_values_for_type(x509.DNSName))
print("Firma: ", cert.signature_hash_algorithm.name)
```

// LO QUE VA EN EL INFORME

Comparen los campos con la evidencia A: emisor, vigencia, nombres amparados y algoritmo de firma. **Después carguen el certificado que emitieron con su propia raíz en el ejercicio 2** y expliquen qué campo haría que un navegador lo rechazara, y cuál no.

LO QUE LLEVAMOS DE LA SESIÓN

01 Un certificado es una afirmación firmada, y vale lo que valga quien la firma

No cifra, no protege: ata una llave pública a una identidad.

02 La confianza no se resuelve, se desplaza

De muchas llaves desconocidas a unas pocas raíces conocidas y auditadas.

03 La revocación funciona mal, y por eso la vigencia se acorta

De 398 días a 47 en pocos años. Eso obliga a automatizar.

04 El candado no dice que el sitio sea legítimo

Dice que el canal está cifrado con quien sea que esté al otro lado.

05 Montar una autoridad propia es asumir un oficio completo

Y el oficio, no el algoritmo, es lo que Coopaburrá no hizo.

QUINTA PARTE DEL PRODUCTO

Se entrega al inicio de la sesión 6, junto con la sustentación. Cierra el hallazgo H7: el valor probatorio de los créditos hipotecarios a veinte años.

SECCIÓN	QUÉ DEBE CONTENER
Diagnóstico jurídico y técnico de H7	Por qué la imagen escaneada no satisface los requisitos de una firma confiable, con las cuatro preguntas del juez respondidas
Esquema propuesto para las firmas nuevas	Firma digital con entidad acreditada, sello de tiempo de tercero y formato de conservación de larga duración
Qué se hace con la cartera ya firmada	La decisión difícil. Resellar, dejar, o documentar el riesgo y provisionarlo. Con el argumento, no solo la elección
Costo y viabilidad	Costo por documento y por año de conservación, y qué preguntas hay que hacerle al proveedor antes de contratar

TRABAJO INDEPENDIENTE HASTA LA SESIÓN 6

11 h

TOTAL ENTRE
MARTES Y JUEVES

3 h

LECTURA
PREVIA

8 h

ENTREGA 5 Y PREPARACIÓN
DE LA SUSTENTACIÓN

Lectura previa · 3 horas

NIST SP 800-57, parte 1

Recommendation for Key Management, secciones 5 y 7: periodos criptográficos y estados de una llave. 1,5 horas.

NIST IR 8547, borrador

Transition to Post-Quantum Cryptography Standards: el calendario de retiro de RSA y de las curvas. Una hora.

CNSA 2.0

Commercial National Security Algorithm Suite 2.0: algoritmos y fechas por tipo de sistema. Media hora.

// CONDICIÓN DE ENTRADA A LA SESIÓN 6

El jueves se recibe la parte 5 y se sustenta la hoja de ruta. Las 8 horas de elaboración son la entrega 5 (6 h, en equipo) y la preparación de la sustentación (2 h): diez minutos por equipo, ante el comité.

LO QUE VIENE EL JUEVES

Sesión 6: el cierre del módulo. Gestión de llaves, conservación a veinte años, transición post-cuántica y sustentación ante el comité.

// BLOQUE 11 • LA LLAVE COMO ACTIVO

Ciclo de vida completo: generación, custodia, rotación, retiro y destrucción.

Ceremonias, doble control y custodios. El hallazgo H6: las llaves de los 32 cajeros, cargadas en 2019 y nunca rotadas.

Y la conservación a veinte años, que es donde se cierra H7.

// BLOQUE 12 • LO QUE VIENE DESPUÉS

La transición post-cuántica: qué se está estandarizando, qué plazos manejan los gobiernos y qué significa grabar hoy para descifrar mañana.

Criptoagilidad: diseñar para poder cambiar de algoritmo sin rehacer el sistema.

Y la sustentación de la hoja de ruta ante el comité.

SIGLAS DE LA SESIÓN · 1 DE 2

ACME

Automatic Certificate Management Environment — Protocolo para pedir y renovar certificados sin intervención humana. RFC 8555.

CAA

Certification Authority Authorization — Registro DNS que indica qué entidades pueden emitir certificados para un dominio.

CA/B Forum / SC

CA/Browser Forum / Server Certificate — El foro de entidades y navegadores, y su grupo de certificados de servidor.

CRL

Certificate Revocation List — Lista de certificados revocados que publica cada entidad de certificación.

DER / PEM / CSR

Distinguished Encoding Rules / Privacy-Enhanced Mail / Certificate Signing Request — Formatos del certificado y de su solicitud.

DNS

Domain Name System — Sistema de nombres de dominio. Aloja los registros CAA y los desafíos de ACME.

HKDF / AES-GCM

Derivación de llaves y cifrado autenticado: las piezas simétricas de TLS 1.3. Sesiones 2 y 3.

HSTS / HTTP

HTTP Strict Transport Security / Hypertext Transfer Protocol — La cabecera que obliga al navegador a usar solo cifrado.

IETF / RFC

Internet Engineering Task Force / Request for Comments — El organismo de estándares de internet y su serie de documentos.

IPsec / IKEv2

Internet Protocol Security / Internet Key Exchange versión 2 — Protocolos de redes privadas virtuales entre sedes.

Toda sigla utilizada en la sesión aparece en el glosario con su forma completa en el idioma original y su equivalencia en español.

SIGLAS DE LA SESIÓN · 2 DE 2

ML-KEM

Module-Lattice-Based Key-Encapsulation Mechanism — Encapsulamiento de llave post-cuántico de FIPS 203. Sesión 6.

NIST / SP / IR

National Institute of Standards and Technology / Special Publication / Interagency Report — El instituto y dos de sus series.

PGP / SSH

Pretty Good Privacy / Secure Shell — Correo cifrado con red de confianza, y acceso remoto con confianza en el primer uso.

ONAC

Organismo Nacional de Acreditación de Colombia — Acredita a las entidades que emiten certificados de persona.

PKCS #12

Public-Key Cryptography Standards #12 — Formato que guarda certificado y llave privada juntos: .p12 o .pfx.

RSA / SHA-1 / SHA-256

Algoritmo de llave pública (sesión 4) y funciones resumen (sesión 3) con que se firman los certificados.

TLS

Transport Layer Security — El protocolo del canal seguro. Las versiones 1.0 y 1.1 están retiradas desde 2021.

USENIX

Asociación estadounidense de sistemas informáticos; su simposio de seguridad publica investigación de referencia.

X25519 / X25519MLKEM768

Acuerdo de llave sobre la curva 25519, y su versión híbrida con ML-KEM-768, activa por defecto en los navegadores.

X.509

Norma de la Unión Internacional de Telecomunicaciones que define el formato de los certificados digitales.

Toda sigla utilizada en la sesión aparece en el glosario con su forma completa en el idioma original y su equivalencia en español.

REFERENCIAS DE LA SESIÓN

Cooper, D. et al. (2008).	RFC 5280: Internet X.509 public key infrastructure certificate and CRL profile. IETF.	Campos y extensiones del certificado
Rescorla, E. (2018).	RFC 8446: The transport layer security (TLS) protocol version 1.3. IETF.	El apretón de manos, mensaje por mensaje
Moriarty, K. y Farrell, S. (2021).	RFC 8996: Deprecating TLS 1.0 and TLS 1.1. IETF.	Retiro de las versiones antiguas
IETF. (2019).	RFC 8555: Automatic Certificate Management Environment (ACME) y RFC 8659: DNS CAA.	Automatización y control de la emisión
CA/Browser Forum. (2025).	Ballot SC-081v3: Introduce schedule of reducing validity and data reuse periods.	Vigencias de 200, 100 y 47 días
Akhawe, D. y Felt, A. P. (2013).	Alice in Warningland: A large-scale field study of browser security warning effectiveness. USENIX Security Symposium.	La habituación a las advertencias
Hodges, J., Jackson, C. y Barth, A. (2012).	RFC 6797: HTTP Strict Transport Security (HSTS). IETF.	Que el navegador no acepte menos

// ACCESO A LAS FUENTES

Los RFC, las decisiones del CA/Browser Forum y el artículo de USENIX son de acceso libre en las páginas de cada organización.